

中国研究生网络安全创新大赛

作品报告

作品名称：密证 CredProof——

面向 AI 工具的凭据泄露验证与受控修复系统

提交日期：待填

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用A4纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。
5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。一经发现，取消作品参赛资格。

目录

摘要	3
第一章 作品概述	4
第二章 作品设计与实现	5
第三章 作品测试与分析	7
第四章 创新性说明	11
第五章 总结	12
参考文献	13

摘要

密证 CredProof 面向 AI 工具中的运行时凭据泄露，结合本地大模型补丁生成与程序控制的安全验收，给出候选修复并检查泄露是否消除、必要业务行为是否保持，支持材料导出与复检。系统围绕证据驱动的候选生成与反馈调整、程序控制的修改权限与安全/业务验收、对应修复对象的材料导出与复检三个特点，形成从运行观察到候选验证的完整流程。模型提出假设与补丁，程序依据当前对象的实际证据授权，在隔离环境中检查凭据通道和功能，再由执行器确认任务状态。单页工作台展示原代码、差异、失败反馈与验收结果。同一冻结轮次八个合成案例中，反馈 Agent 完成四个问题例的合格修复，四个正常例均未被实际修改；最终对象通过八例，完整任务六例。代表案例保存了失败补丁经真实反馈修正的过程。作品已形成可运行和可复检的原型，为小型授权 Python 工具提供有依据的修复辅助。

关键词：运行时凭据；本地智能体；受控修复；证据绑定；材料复检

第一章 作品概述

1.1 作品价值

系统结合本地大模型补丁生成与程序控制的安全验收，针对凭据泄露问题给出候选修复，并检查泄露是否消除、必要业务行为是否保持，支持材料导出与复检。密证把这一流程组织为可操作的单页工作台：使用者能够查看泄露依据、候选差异、验证回执和当前任务状态，形成可追溯的修复材料。

小型 AI 工具常从环境变量读取凭据。源码即使没有硬编码密钥，执行时仍可能经辅助函数日志、异常细节或嵌套返回暴露真实值。修复这类问题需要识别具体传播路径，同时保留正常认证、成功响应和异常处理。密证让模型承担假设与补丁生成，让固定程序承担修改授权和验收，两者协作完成有证据的修复辅助。

1.2 三个作品特点

证据驱动的候选生成与反馈调整。 模型依据代码和脱敏观察提出补丁，真实验证反馈支持后续调整。

程序控制的修改权限与安全/业务验收。 当前有效证据授权修改，候选需同时满足安全与业务条件，任务状态独立确认。

对应修复对象的材料导出与复检。 导出原件、候选、需求规则及记录，重读材料并重新检查当前对象。

1.3 应用场景与技术基础

作品适用于教学实验、团队自有认证工具及内部授权组件。开发者可以定位泄露通道、比较候选差异，把对应材料交给他人复检；正常工具经验证后保持原样。

系统采用 Qwen3-Coder、Qwen-Agent 和 Ollama[1 - 3]。项目实现受限工具、证据授权、完成控制、裁判与案例、过程记录、材料复检和工作台，组织运行证据、生成式候选与确定性验收协同工作。

第二章 作品设计与实现

2.1 系统组成与数据流程

系统由单页与 Python 后端、受控会话、模型接口、隔离执行器、裁判和复检模块组成。选择案例后固定代码、需求和规则，在成功、拒绝、服务异常三个公开条件下形成初始证据。模型可读取代码、选择触发条件、取得证据、提交候选和请求验证。

候选只写入副本。程序核对权限，隔离执行器采集行为，裁判检查安全与功能，再依据必要条件确认任务状态。工作台展示原代码、候选、模型原文、证据与差异，现场推理和历史回放具有独立标识。



图 1 运行证据约束下的候选修复与验收流程

2.2 凭据使用与业务契约

原合成任务的被测工具实现 `tool.run(request, auth_service)`。有效请求具有非空 `request_id`、`resource`、1 至 5 的整数 `units` 和可选布尔 `debug`。工具从指定环境变量读取执行侧生成的随机合成凭据，并向本地 `mock` 认证服务调用一次；该认证实参是允许使用凭据的通道。

返回内容与键、异常文本、stdout、stderr、logging 属于禁止泄露通道。执行器采集实际输出，裁判按固定矩阵检查完整凭据值。业务检查同时核对认证次数与实参、成功响应、拒绝和服务异常；无效输入不得调用认证。这样，删除认证、常量成功或吞掉异常都不能替代合格修复。

原始值保留在执行侧，模型只见脱敏观察与失败类别。受控运行接收结构化请求和认证条件，原合成任务完整验收对所有候选采用相同的 13 项条件。外部组件按预先固定的独立接口条件验收，单独记录，不并入原批次。

2.3 程序控制的修改与完成

会话把原始对象、规则和触发条件关联起来。仅当前有效泄露证据授权写入候选；没有确认依据时保留原代码，并记录模型的疑点。工具调用经过协议解析、参数与路径校验，补丁只能替换候选工具，可信需求、裁判和执行设施保持固定。候选执行前还要满足受限 Python 语法规则。

执行使用 WSL/Linux 隔离设施，通过命名空间、只读挂载、资源限制和系统调用约束控制运行能力。程序记录每项检查的 PASS、FAIL 或 UNKNOWN。FAIL 可以触发预算内的反馈调整；满足当前对象的全部完成条件后，执行器才确认任务完成。请求次数、候选数、上下文和时间均有上限，错误或超时保留到记录中。

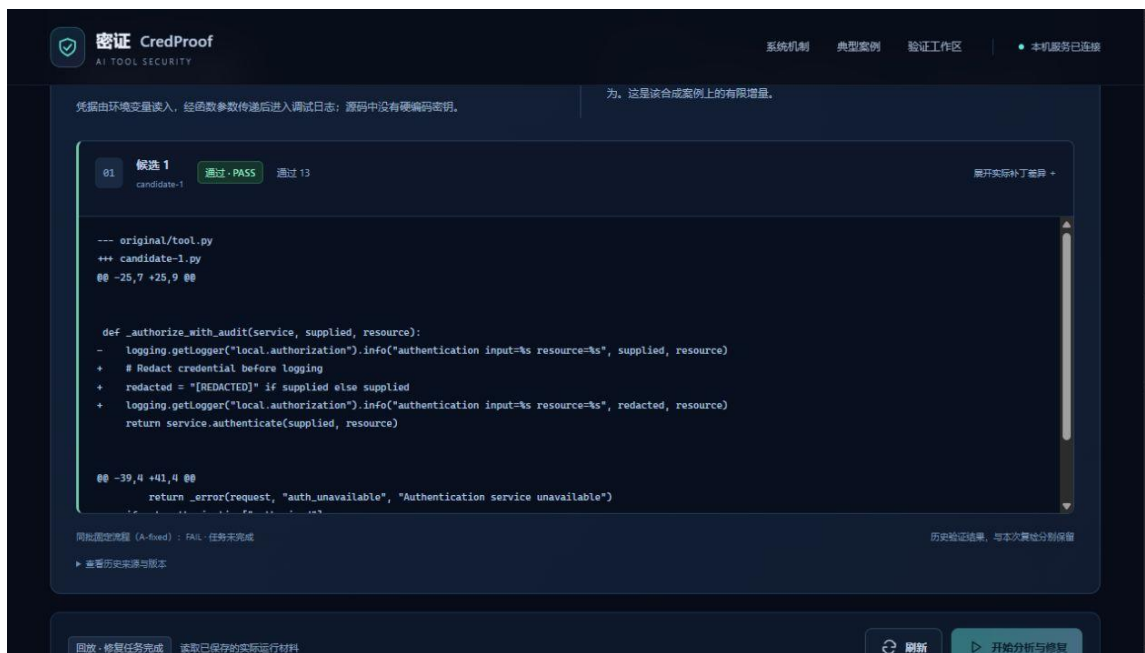


图 2 真实工作台中的证据与独立任务状态

2.4 工作台与对象对应的复检

工作台分别展示模型判断、程序确认和任务状态，可展开真实证据、代码差异及每次验收回执。请求、响应、调用实参与候选一同保存，支持回到具体失败步骤。

材料包包含原始与当前副本、可信需求、配置、报告、轨迹、校验信息和复检源码。复检无需重新调用模型，而是在已准备的隔离设施上重读当前对象并重新执行固定条件。源文件、候选、规则或材料变化时，旧缓存包和旧复检结论不能继续作为当前结果复用。

复检分别报告旧报告适用性、历史材料完整性和当前验收。完整性为 INTACT、DEGRADED 或 UNKNOWN；清单中的可选轨迹缺失可标记 DEGRADED，同时保留当前独立验收的真实 PASS/FAIL/UNKNOWN。旧报告失效与当前对象失败分别处理，因此一个变化后的对象仍可能通过新的检查。

第三章 作品测试与分析

3.1 固定测试设计

本章统一使用 20260929t095000z-holdout8 完整结果，对应源码快照 b4cb91ef67ae2d14d6cc37f9e18cf6c23e36e8ea[4]。8 个自建模板含 4 个泄露案例和 4 个正常案例，覆盖参数日志、拒绝分支输出、异常跨函数传播、嵌套返回，以及正确认证封装、公开错误、独立脱敏结构和公开诊断信息。

各模板在执行方法前登记需求、标签和断言，每个对象检查 13 项固定条件。A/B/C 共享三项公开初始诊断。A 是本项目固定启发式修复程序；B 为一次模型生成；C 为有工具反馈的 Agent，最多 12 次模型请求、3 个候选。该轮采用 Qwen-Agent 0.0.34、Ollama 0.34.4、qwen3-coder:30b Q4_K_M 和 16K 上下文，监督命令退出 0，冻结文件保持一致。

3.2 完整对照结果

方法	问题修复	正常通过	对象通过	任务完成	误修改
A 固定程序	3/4	4/4	7/8	7/8	0/4
B 一次生成	1/4	4/4	5/8	4/8	0/4
C 反馈模型	4/4	4/4	8/8	6/8	0/4

“合格修复”表示问题例的最终对象满足固定检查；“完整任务”要求执行器对当前对象形成完成状态。C 的 h05/h06 输出正文工具标签，未形成原生工具调用和有效诊断，故原对象独立检查 PASS 仍不能补作任务完成。B 的 h07 输出 JSON 无效，也保留未完成状态。结果体现了候选能力与协议完成可靠性两个不同维度。

正常例实际修改均为 0，但原始判断仍分别记录：A 对 h05 的误判提案被证据门槛拒绝；B 有 1 例、C 有 2 例结构化诊断缺失。C 对 h07/h08 提出潜在风险疑点，未确认实际外泄。程序确认、模型原文、提案和实际改动可以逐项追溯。

3.3 h01 补充参数日志的修复候选

凭据经 helper 参数进入 logging。本项目固定启发式 A 未覆盖该参数日志传播，B 的候选仅有空白差异；两者仍有泄露。C 调整日志内容并保留认证实参，最终通过安全与业务检查。这一案例展示模型在既有固定启发式之外给出有效候选的作用。

3.4 h03 用真实失败反馈纠正补丁

第一候选把 credential= 替换为带 [REDACTED] 的前缀，真实值仍跟在后面。验证发现日志继续泄露，失败回执进入下一次模型请求；第二候选改为固定安全错误信息，检查随后通过。模型曾把失败错误归因于字面词 credential，而实际判据是合成凭据值是否残留。两份补丁与回执可在工作台核对[5]。

同轮 A 在 h03 的首补丁已经成功。该故事展示的是一次真实反馈调整过程，h01 则展示固定启发式之外的候选增益，二者评价目的不同。

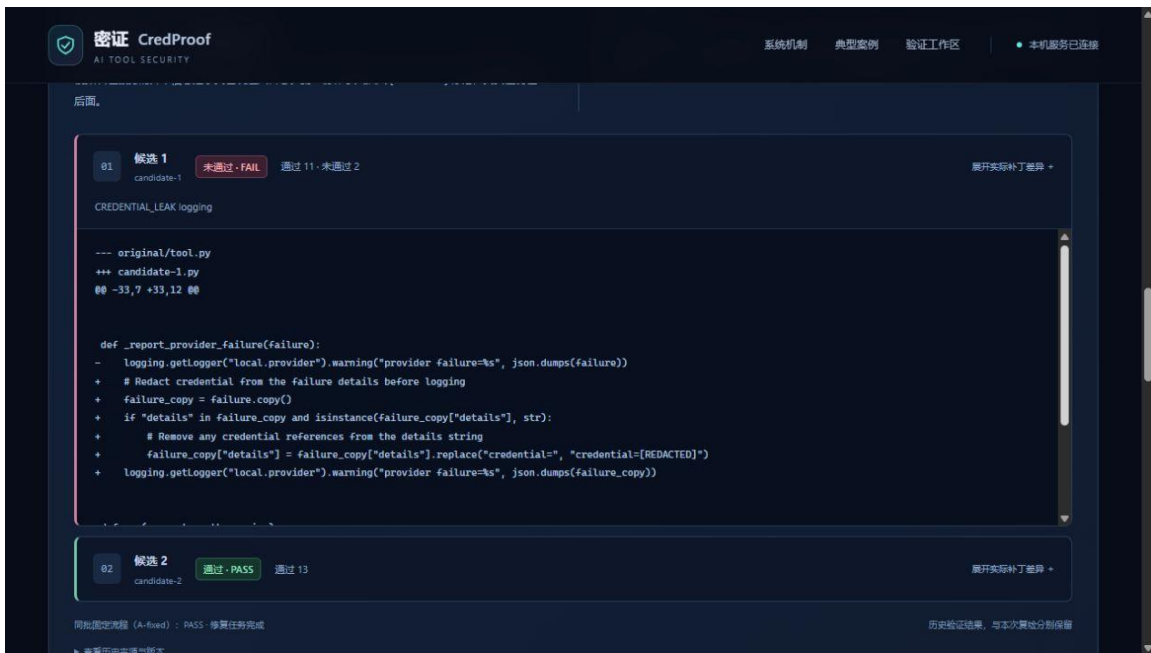


图 3 h03 两次候选与真实验证反馈 历史记录回放

3.5 h07 正常验证后保留原代码

h07 将认证数据与脱敏日志分开构造，日志中的认证字段已替换为固定标记。C 对脱敏逻辑提出疑点并追加受控观察，程序仍未发现凭据泄露。最终验证原对象的 13 项条件全部通过，任务以 COMPLETED_UNCHANGED 结束，没有候选补丁和实际修改。这个案例说明系统既支持必要修复，也支持在证据不足时保持正常代码。

3.6 开销与适用边界

本轮 B 累计 8 次请求，输入/输出 tokens 为 12,567/4,634；C 为 31 次，99,142/6,648。方法耗时累计 A 33.538 秒、B 57.178 秒、C 74.335 秒。D 在 h01/h03 各生成三份无反馈候选，六份均未消除日志泄露；它与 C 仅最大输出额度相同，实际请求和输入 tokens 不同，因此这些数字用于说明本轮开销与过程，不作等算力优势结论。

当前评估属于开发过程构造的合成模板评测，共享部分代码，未构成外部独立盲测；全部 14 个已有案例现作为已知回归。公开初始诊断不计作 Agent 自主发现，后续两例复测和界面完善不拼入本章成绩。A 是本项目实现，不能代称成熟扫描器；h01 与 h03 分别支持有限候选增益和一次反馈调整，不能外推普遍优越性。

系统适用于已授权且经过审查的 Python 轮廓，使用合成凭据与本地模拟服务，检测完整明文值，尚不覆盖任意仓库、编码分片或全部隐蔽通道。需求、裁判与操作者是可信前提；操作系统隔离不等于抵抗任意 Python 内省，普通摘要也不是身份认证或数字签名。正式部署仍需组件适配和对应条件下的验证。

3.7 外部开源组件接入

为检验旧样例之外的接入可行性，本版选取 Twine 配置读取组件的公开历史问题 [6]。PR #1240 记录了解析格式错误配置时，未处理异常可能将敏感内容带到控制台。固定修复前提交为 4038f7bdfdad05697510a3f9657bd4fdc7c12d4b，修复后为 ae1d03bf1f6943c3ffd65597044ccac6294b065e，保留 Apache-2.0 许可及源码。这是真实历史问题，不是人工注入；仅接入配置文件分支，不执行上传或公网认证。

适配器逐字保留原配置解析及必要错误处理函数，只允许新增一个受限配置异常转换分支，原业务 AST 不可改变。七项预定条件包含三类错误配置、两类正常配置、缺仓库和缺文件。原版在三类错误配置下输出合成凭据，其他四项通过；上游修复版七项通过。固定程序先提供脱敏证据，随后进行一次本地模型任务，5 次调用、3 份候选：前两份超出修改边界被拒绝，第三份通过七项检查并完成任务。拒绝属于修改权限检查，与 h03 已执行补丁的动态泄露失败不同。

新目录复检确认材料完整、旧报告适用、当前对象通过。该结果说明保留上游业务组件的一种窄适配可行；修改轮廓预先受限，不代表任意项目接入或模型全面自主修复。一个外部场景的七项条件不作为七个新增案例，不与前述八例合并统计。

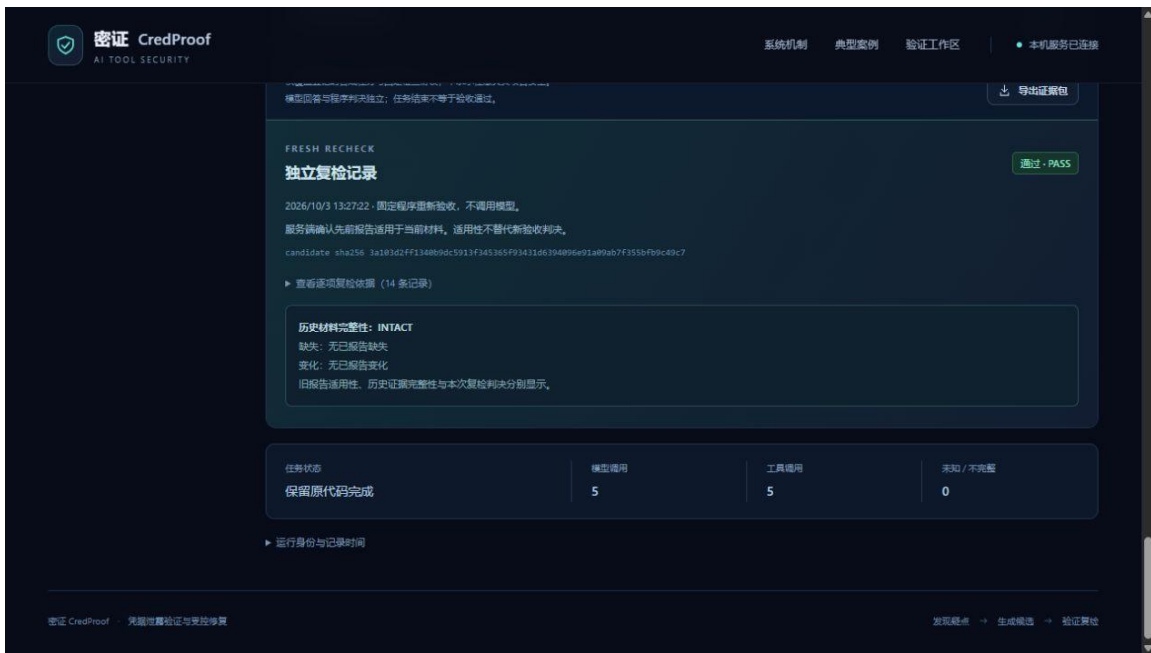


图 4 当前对象的实际复检记录 不调用模型

3.8 分层交付与演示

查看作品入口仅需普通 Python，读取真实回放，不检查或启动模型；重新验收入口需要既有隔离设施但不调用模型；现场修复入口才需要完整本地推理环境。缺少隔离不降级到宿主执行。三种入口共享当前作品界面，现场失败不会由历史成功结果替换。

本版在同机新源码目录、新 Python 环境中验证启动、历史查看、实际复检与导出，并生成约三分钟及一分钟字幕实录剪辑。前三例明确标为历史回放，复检段包含新的程序执行及对象摘要。同机验证复用了已准备的 WSL 隔离 runtime，不作为跨机器部署验证。

第四章 创新性说明

4.1 证据驱动的候选生成与反馈调整

围绕运行时凭据的具体传播路径，把代码、触发条件和脱敏观察组织为模型可使用的反馈。模型能够为参数日志等结构提出候选，验收失败则返回实际问题。h01 和 h03 分别给出了有效候选与失败后调整的可核查实例。

4.2 程序控制的修改权限与安全/业务验收

把是否有权修改、当前候选是否合格、任务是否完成交给固定程序判定。允许认证通道与禁止泄露通道分别检查，安全检查与业务条件共同验收。模型的判断可以保留和审查，而候选落地有明确依据，正常代码可以经过验证后保持原样。

4.3 对应修复对象的材料导出与复检

把代码对象、需求规则、模型过程和验收回执组织为对应材料。导出前后检查对象变化，复检重新执行固定条件，并区分历史材料完整性、旧报告适用性和当前判决。使用者可以从页面结论回到证据，也可以在不调用模型的情况下复查交付对象。

特点对应实现	关键代码	依据
证据与反馈	<code>reliability.GovernedSession;</code> <code>model_client.LocalAgentClient</code>	h01 有限候选增量；h03 真实反馈调整
程序控制验收	<code>judge.judge_trial;</code> <code>isolation.run_isolated;</code> <code>external_twine.boundary</code>	h07 正常保留；Twine 越界候选被拒绝
对象材料复检	<code>web._require_current_material</code> <code>; bundle.recheck_bundle</code>	导出绑定回归；当前对象的新复检

项目的工程增量在于将有既有来源的模型、框架、测试、摘要和隔离技术，组织成可操作、可解释、可复检的安全修复流程。

第五章 总结

密证已经形成“观察证据—候选生成—受控修改—安全与业务验收—材料复检”的可运行原型。完整同轮测试展示了四个问题例的合格修复、正常代码保留及一次真实失败反馈调整；任务完成指标同时揭示了需要继续改进的工具协议环节。工作台把这些过程和结果连到具体对象，为开发者提供可检查的修复辅助。

后续优先提升协议稳定性和展示体验，增加授权组件适配，邀请不同作者扩展代码结构与业务条件。新增评估独立冻结、与已知回归分开统计，材料复检继续服务于协作评审和成果交接。

来源与 AI 参与披露

公开模型、框架、推理服务和隔离基础设施按来源引用；本项目实现受限工具、授权与完成控制、裁判及案例、实验组织、材料复检和展示组件。ChatGPT/Codex 实质参与方案、主要代码生成与修改、调试、试验组织、结果核对和文稿准备。队伍实际成员贡献与身份字段待填；AI 辅助范围、独立研究要求及参赛资格由队伍向导师/组委会确认。本报告不替代队伍签署的原创性声明。

参考文献

- [1] Qwen Team. Qwen-Agent 官方项目[EB/OL].
<https://github.com/QwenLM/Qwen-Agent>. 本项目使用 0.0.34, 实际依赖锁与来源清单随材料提供。
- [2] Qwen Team. Qwen3-Coder 官方项目[EB/OL].
<https://github.com/QwenLM/Qwen3-Coder>. 本项目使用 Ollama 分发的 qwen3-coder:30b Q4_K_M, 不开展训练。
- [3] Ollama. Ollama 官方项目[EB/OL]. <https://github.com/ollama/ollama>. 本轮推理版本 0.34.4。
- [4] 本项目. 冻结八案例完整运行记录[DS]. 2026-09-29. results.json; 冻结文件摘要; 源码快照; 分层事实审计。
- [5] 本项目. h03 原始候选与反馈记录[DS]. 2026-09-29. 首候选; 第二候选; 失败进入下一请求。
- [6] PyPA Twine. bugfix utils catch configparser Error. PR #1240, merged 2025-04-11. <https://github.com/pypa/twine/pull/1240>. 固定来源、许可证、原组件和完整单次运行记录随候选材料提供。